

Access Control & Least Privilege Policy

1. Purpose

This policy establishes the framework for granting, managing, reviewing, and revoking access to Summit IT Services systems, applications, and data. The core principle is **least privilege**: every user, system, and process should have access only to the resources required to perform its function - no more. This policy reduces the risk of insider threats, lateral movement after a breach, and accidental data modification.

2. Scope

This policy applies to:

- All Summit IT Services employees, contractors, temporary workers, vendors, and service accounts.
- All systems and applications for which access is managed, including Okta, Microsoft 365, SharePoint, OneDrive, Teams, Slack, Zoom, SummitDesk, AWS, CrowdStrike, Intune, Jamf Pro, and any other business application.
- All privileged accounts with elevated system rights.
- Access provisioned at initial hire, changed due to role changes, and removed at offboarding.

3. Policy Statements

3.1 Access Provisioning

3.1.1 Access to Summit IT Services systems is granted based on **role-based access control (RBAC)** through Okta groups. Access is mapped to job function and business need, not seniority or convenience.

3.1.2 Access provisioning is initiated through the following workflows:

Trigger	Process
New employee hire	HR submits onboarding request in SummitDesk; Okta group assignment provisioned by L2 based on role template
Contractor / vendor onboarding	Sponsoring manager submits SummitDesk request; access limited to specific systems and time-boxed
Role change / promotion	Manager submits access change request in SummitDesk; old access reviewed and revoked if no longer needed

Project-based access need	Employee or manager submits SummitDesk request with business justification; access time-limited to project duration
---------------------------	---

3.1.3 Access must be provisioned before the employee's first day but activated only on the start date. Pre-activation of accounts is prohibited except for IT administrator setup purposes.

3.1.4 Contractors and vendors must be issued individual, named accounts. Shared generic accounts for external parties are prohibited.

3.1.5 Role access templates (Okta group sets) are maintained by IT Security and reviewed annually. Managers must review templates for their roles during the annual access review cycle.

3.2 Least Privilege Requirements

3.2.1 Users must be granted only the access required to perform their current job function. Requests for broader access require written business justification and manager approval.

3.2.2 Privileged access (local admin, application admin, infrastructure admin) must be **separate accounts** from the user's day-to-day account. Administrators must use their standard account for email, browsing, and productivity tasks, and their privileged account only when performing administrative tasks.

3.2.3 Privileged accounts are subject to additional MFA requirements per POL-003 (YubiKey mandatory).

3.2.4 Default-deny is the baseline: access to new systems or resources is denied by default until explicitly provisioned.

3.2.5 Employees who transfer to a new role must have their access adjusted to match the new role within **5 business days**. Old access must be removed at the same time as new access is granted - accumulation of access from previous roles ("access creep") is prohibited.

3.3 Privileged Access Management

3.3.1 Privileged accounts include but are not limited to:

Account Type	Examples
Okta Super Admin / Admin	Okta admin console full access
Microsoft 365 Global Admin	Exchange admin, SharePoint admin, Intune admin
AWS IAM privileged roles	AdministratorAccess, PowerUserAccess
CrowdStrike Admin	Falcon console administrative rights
Jamf Pro Admin	Full MDM management

Local device admin	Local administrator on Windows or macOS endpoints
--------------------	---

3.3.2 The number of privileged accounts must be minimized. IT Security maintains a register of all privileged accounts; additions require CISO approval.

3.3.3 Privileged accounts must not be used for day-to-day work (email, web browsing, document editing). Privileged access sessions must be terminated immediately after the task is complete.

3.3.4 Local administrator rights on end-user devices are removed by default. Temporary elevation for approved software installation is handled via the Intune and Jamf managed install mechanisms. Requests for persistent local admin rights require a security exception approved by IT Security.

3.3.5 All privileged account activity is logged and monitored. Logs are retained for a minimum of 1 year. Anomalous privileged activity generates SOC alerts.

3.4 Access Reviews

3.4.1 **Quarterly access reviews:** IT Security & Compliance conducts quarterly reviews of all privileged accounts and contractor/vendor accounts. Account owners must confirm continued necessity or accounts are deactivated.

3.4.2 **Annual access reviews:** All employee access is reviewed annually. Managers receive a report of their team's current application access and must certify accuracy within 15 business days. Uncertified access is revoked automatically.

3.4.3 **Event-triggered reviews:** Access reviews are triggered immediately upon: - Employee role change or transfer. - Project completion (project-based access). - Security incident involving the account. - Contractor/vendor contract expiration.

3.4.4 Access review results are documented in the IT GRC system. Findings of inappropriate access are remediated within 5 business days.

3.5 Access Revocation and Offboarding

3.5.1 When an employee or contractor leaves Summit IT Services, access revocation must follow these timelines:

Departure Type	Okta Account Disable	M365 / SaaS Disable	Device Return
Voluntary resignation (standard notice)	Last working day, 5:00 PM local time	Last working day, 5:00 PM local time	Last working day
Involuntary termination	At or before exit meeting	At or before exit meeting	At or before exit meeting
Contractor end of engagement	Contract end date	Contract end date	Per agreement

3.5.2 Okta account deactivation automatically cascades to all Okta-connected applications via SCIM or Okta provisioning. Applications not connected to Okta must be manually deactivated; a checklist of such applications is maintained by L2 Desktop & Systems and reviewed as part of every offboarding.

3.5.3 Data in departed employees' OneDrive accounts is transferred to their manager for a period of 90 days before deletion, subject to any applicable legal hold.

3.5.4 Email forwarding from a departed employee's mailbox may be set up for a maximum of 30 days. Shared mailboxes or distribution lists must be updated to remove the departed employee's address.

3.6 Shared and Service Accounts

3.6.1 Shared accounts (accounts used by more than one person) are strongly discouraged. Where required for technical reasons, shared accounts must: - Be documented in SummitDesk with a named owner responsible for the account. - Not be used for privileged tasks. - Have credentials stored in a 1Password shared vault with access limited to authorized users. - Have all activity logged and attributable where possible through session attribution.

3.6.2 Service accounts (accounts used by automated systems, scripts, or applications) must: - Be created with a unique, descriptive name indicating the owning system. - Have the minimum permissions necessary for their function. - Use API keys or OAuth service credentials rather than username/password where the platform supports it. - Have credentials stored in 1Password Secrets Automation or AWS Secrets Manager; never hardcoded. - Be reviewed quarterly and disabled when the owning system is decommissioned.

3.7 External / Third-Party Access

3.7.1 Third-party vendors requiring system access must: 1. Be sponsored by a named Summit IT Services employee with manager approval. 2. Have a signed agreement (NDA or vendor contract) on file with Legal. 3. Be provisioned with the minimum access scope required; all access must be time-limited. 4. Use their own named individual accounts - no sharing of Summit IT accounts with vendor staff.

3.7.2 External access to internal systems must route through GlobalProtect VPN or a dedicated vendor access portal. Direct internal system access from the internet is prohibited.

3.7.3 Vendor access is reviewed monthly by the sponsoring employee and quarterly by IT Security. Access is revoked immediately when the engagement ends.

4. Roles & Responsibilities

Role	Responsibility
All Employees	Use only provisioned access; report access anomalies; complete access review certifications promptly
Managers	Approve access requests for their team; certify annual access reviews; notify HR/IT of role changes and departures immediately

IT Service Desk (L1)	Accept and route access requests; execute offboarding checklists
L2 Desktop & Systems	Provision/deprovision accounts; manage Okta group membership; maintain non-Okta app deactivation checklist
IT Security & Compliance	Own policy; maintain privileged account register; conduct access reviews; monitor for access anomalies
L3 Engineering	Maintain Okta RBAC configuration and SCIM provisioning; configure AWS IAM; enforce least privilege technically
HR	Trigger onboarding and offboarding workflows; notify IT of same-day terminations immediately
Legal	Advise on vendor access agreements; manage legal holds affecting account data

5. Enforcement & Consequences

5.1 Access provisioning and deactivation are enforced through automated Okta workflows and Intune/Jamf policies. Unauthorized access detected by SOC monitoring generates immediate investigation.

5.2 Policy violations:

- **Accessing a system beyond provisioned role:** Account investigation; access revoked; HR discussion.
- **Using another employee's credentials:** Immediate account suspension; HR/Legal investigation; potential termination.
- **Failing to report a role change for access update:** Written warning; immediate access review.
- **Sharing privileged credentials:** Formal written warning; privileged account revoked; re-certification required.
- **Failure to complete access review certification within deadline:** Uncertified access automatically revoked; escalation to manager.

6. Exceptions

Access exceptions (e.g., emergency access to a system outside normal scope, or shared accounts required by legacy applications) must be approved by the data/system owner, IT Security, and CISO. Exceptions must be time-limited, logged, and reviewed monthly.

7. Related Documents

- POL-002 - Password & Authentication Policy

- POL-003 - Multi-Factor Authentication Policy
- POL-005 - Data Classification & Handling Policy
- POL-007 - Software Installation & Licensing Policy
- POL-010 - IT Asset Management Policy
- REF-0001 - Summit IT Environment Standards
- Okta Access Provisioning Runbook (internal wiki)
- Offboarding IT Checklist (internal runbook)

8. Revision History

Version	Date	Author	Summary of Changes
1.0	2020-09-01	IT Security	Initial access control policy
2.0	2022-07-01	IT Security & Compliance	Introduced Okta RBAC model; added privileged account register; formal offboarding timelines
2.1	2023-02-15	IT Security & Compliance	Added contractor access review monthly cycle; shared account documentation requirements
2.2	2023-09-01	IT Security & Compliance	Added service account API key requirements; secrets manager guidance
2.3	2024-01-01	IT Security & Compliance	Added quarterly access review for privileged accounts; access creep prohibition
2.4	2025-01-10	IT Security & Compliance	Annual review; updated offboarding timing table; aligned with Okta SCIM capabilities

2.5	2026-03-01	IT Security & Compliance	Annual review; added event-triggered review section; no structural changes
-----	------------	--------------------------	--